

AI Audit Report — Member 3 (23127185)

Sinh viên: Mai Thị Kim Duyên — MSSV 23127185 — Branch me lyen **Khai báo:** I use AI tools for the following tasks. **Công cụ:** Claude Code (Claude Opus 5, Anthropic) — CLI, phiên làm việc HW06 trên repo HCMUS-software-testing/HW06. **Skill B:** agent-skill/audit_logger.py — chỉ append phiên đã xảy ra, không bịa log. **Transcript đầy đủ:** docs/ai-audit-transcripts/ **Ghi chú thời gian:** các phiên diễn ra trong khoảng 2026-08-31 → 2026-09-01 (timezone local Asia/Ho_Chi_Minh). ISO dưới đây là thời điểm ghi audit, không phải thời điểm model trả lời từng token.

Quy ước quyết định: **ACCEPT** = dùng nguyên; **REVISE** = dùng sau khi người sửa; **REJECT** = không dùng.

AUDIT-1

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T21:10:00+07:00
- Task: FR-01 extract parameters / constraints / schema (Prompt 1)
- Prompt:

Đây là đoạn spec + SRS của FR-01 (`POST /api/register``, body: name, email, password). Liệt kê parameters, ràng buộc, actor/role, status code, response schema. Chưa sinh test.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p1-fr01-extract.out.md)

name/email/password required. Email unique + format. Password >=8 + hoa/thường/số/@\$!%*?&. Public API. 200 {message,id} / 400 / 409.

- Human decision: ACCEPT
- Follow-up: Nạp constraint vào parser skill. Ghi nhận SUT không validate — tách discovery.

AUDIT-2

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T21:25:00+07:00
- Task: FR-01 EP + BVA từng parameter (Prompt 2)
- Prompt:

Từ bảng constraint FR-01, làm equivalence partitioning + BVA cho từng parameter (name, email, password). Một hàng = một class. Chưa gộp thành test case.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p2-fr01-ep-bva.out.md)

18 partition: name empty/missing/XSS/long; email format/SQLi/duplicate; password length 7/8/9 + thiếu từng class ký tự.

- Human decision: REVISE
- Follow-up: Thêm partition case-insensitive duplicate (H01) và Content-Type form-urlencoded (H02) — AI miss.

AUDIT-3

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T21:40:00+07:00
- Task: FR-01 security matrix SEC-01..07 (Prompt 5)
- Prompt:

Liệt kê SEC-01..07 cho POST /api/register: SQLi/XSS name/email; unauthenticated (public); mass-assign role=admin; oversized payload; Content-Type lệch.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p5-fr01-security.out.md)

SQLi/XSS/mass-assign role. Public nên không 401. Oversized name.

- Human decision: REVISE
- Follow-up: AI bỏ Content-Type crash 500 và email khác case. Mass-assign role AI có — SUT ignore, đưa sanity.

AUDIT-4

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T21:55:00+07:00
- Task: FR-01 schema + gom ID ≥ 35 (Prompt 6)
- Prompt:

Gộp thành M3-FR01-<nnn>. Mỗi case: precondition, body, expected status, keys, technique. ≥ 35 . Đánh dấu chỗ thiếu.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p6-fr01-schema.out.md)

40 AI cases: 7 sanity / 31 discovery / catalog. Schema 200 {message,id}.

- Human decision: REVISE
- Follow-up: 1 INCOMPLETE (round-trip phụ thuộc FR-02). Human 6 case. Audit CSV: VALID 45, INCOMPLETE 1.

AUDIT-5

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T22:15:00+07:00
- Task: FR-09 extract C1–C5 + công thức (Prompt 1)
- Prompt:

Đây là đoạn spec + SRS của FR-09 POST /api/apply-coupon. Liệt kê parameters, ràng buộc C1–C5, actor/role, status code, response schema, công thức percent/fixed. Chưa sinh test.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p1-fr09-extract.out.md)

C1 exist+active, C2 not expired, C3 total $\geq$ min, C4 JWT, C5 remaining uses.
 $\text{percent} = \text{total} * \text{discount_value} / 100$.

- Human decision: ACCEPT
- Follow-up: Parser bắt cụm "lớn hơn hoặc bằng" từ SRS, không cop > từ SUT.

AUDIT-6

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T22:30:00+07:00
- Task: FR-09 EP/BVA (Prompt 2)
- Prompt:

Từ constraint C1–C5 + field code/total_amount/user_id, làm EP + BVA. Một hàng một class. Chưa gộp test.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p2-fr09-ep-bva.out.md)

code valid/unknown/empty/SQLi/EXPIRED; total 0 / min-1 / min / min+1 / âm; user_id omit/self/other/string.

- Human decision: REVISE
- Follow-up: AI dùng min exclusive. Sửa inclusive. BVA SAVE10 299999/300000/300001.

AUDIT-7

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T22:45:00+07:00
- Task: FR-09 decision table C1–C5 (Prompt 3)
- Prompt:

FR-09 apply-coupon có 5 điều kiện đồng thời: C1..C5. Làm decision table. Công thức percent theo spec: $\text{total} * \text{discount_value} / 100$.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p3-fr09-decision.out.md)

6 hàng: all T → 200; từng C false → 404/400/401/400. BVA C3 299999/300000/300001.

- Human decision: REVISE
- Follow-up: AI thoảng viết C3 > vì nhìn SUT; người giữ >=. AI không nghĩ omit user_id bypass C5 → H05.

AUDIT-8

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T23:00:00+07:00
- Task: FR-09 state / lifecycle (Prompt 4)
- Prompt:

Mô tả lifecycle coupon khi apply: VIP100 max 2 lần 3; EXPIRED; admin xoá giữa chừng; tạo percent=1000 rồi apply.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p4-fr09-state.out.md)

Create-apply lần 1/2/3; EXPIRED 400; DELETE rồi apply 404.

- Human decision: REVISE
- Follow-up: AI không nối FR-17 percent=1000 với overflow FR-09. Thêm H03 FR-17 + case overflow.

AUDIT-9

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T23:15:00+07:00
- Task: FR-09 security SEC-01..07 (Prompt 5)
- Prompt:

Liệt kê vector SEC-01 đến SEC-07 cho POST /api/apply-coupon. Mỗi vector: precondition, expected status theo spec.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p5-fr09-security.out.md)

SQLi code; missing JWT 401; IDOR user_id; mass-assign ignore; oversized.

- Human decision: REVISE

- Follow-up: AI liệt kê IDOR nhưng không nhấn quota victim (H02). Omit user_id bypass C5 không phải SEC-05 cổ điển nên model bỏ (H05).

AUDIT-10

- Tool: Claude Code (Opus 5)
- Date/time: 2026-08-31T23:40:00+07:00
- Task: FR-17 extract CRUD (Prompt 1)
- Prompt:

Đây là đoạn spec CRUD coupon: GET /api/coupons, POST /api/admin/coupons, DELETE /api/admin/coupons/:id. Liệt kê field, role, status, schema. Chưa sinh test.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p1-fr17-extract.out.md)

GET list admin 200/401/403. POST required code/type/discount/expired_at. DELETE 200/401/403/404. Duplicate 409.

- Human decision: REVISE
- Follow-up: Path mismatch GET /api/admin/coupons vs /api/coupons → H01. authenticateToken không check role → SEC-03.

AUDIT-11

- Tool: Claude Code (Opus 5)
- Date/time: 2026-09-01T00:05:00+07:00
- Task: FR-17 schema + gom ID ≥ 35 (Prompt 6)
- Prompt:

Gộp GET /api/coupons, POST /api/admin/coupons, DELETE /api/admin/coupons/:id thành M3-FR17- $\langle nnn \rangle$. ≥ 35 . Spec là oracle.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p6-fr17-schema.out.md)

40 AI cases: happy POST/GET/DELETE; user token 403; invalid create 400; missing id 404; duplicate 409.

- Human decision: REVISE
- Follow-up: DELETE missing id giữ expected 404 (SUT luôn 200). Basic auth expected sửa 403 (FR-17-035). Duplicate 409 vs SUT 500 → H05.

AUDIT-12

- Tool: Claude Code (Opus 5)

- Date/time: 2026-09-01T00:40:00+07:00
- Task: Implement Skill A generator + emit Postman/Excel
- Prompt:

Viết agent-skill/generate_api_tests.py: parser + heuristic + validator, xuất CSV + Postman (sanity vs discovery) + Excel. Pre-request upsert X-Student-Id.

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p7-skill-generator.out.md)

generate_api_tests.py ~65KB. Outputs: FR-01/09/17.csv, member-3.xlsx, HW06_Member3.postman_collection.json.

- Human decision: REVISE
- Follow-up: Sửa FR-17-035 403; thêm 00_Setup_Auth vào discovery; sửa cú pháp FR-09-019. Không nhờ AI generate Newman HTML.

AUDIT-13

- Tool: Claude Code (Opus 5)
- Date/time: 2026-09-01T09:20:00+07:00
- Task: Chẩn đoán fixture drift SAVE10 sau Discovery
- Prompt:

Sanity fail M3-FR09-008 (expected 400, got 200, discount_amount -2699991). Probe DB. Vì sao SAVE10 min=1?

- AI output: (rút gọn; full: docs/ai-audit-transcripts/p8-fixture-drift.out.md)

FR-17-008 DELETE id=1 (user token, SUT 200) xóa SAVE10; FR-17-010 POST lại min=1. Quy trình: reseed → discovery → reseed → sanity.

- Human decision: ACCEPT
- Follow-up: Không đổi expected spec. Reseed giữa 2 suite. Ghi BUG-M3-017.

AUDIT-14

- Tool: Claude Code (Opus 5)
- Date/time: 2026-09-01T10:10:00+07:00
- Task: OpenAPI excerpt Member 3 (optional)
- Prompt:

Viết openapi/eshop-member3.yaml cho FR-01/09/17. Expected responses theo spec, không theo SUT. Header X-Student-Id required.

- AI output: (rút gọn)

openapi 3.0.3, 5 path: /api/register, /api/apply-coupon, /api/coupons, /api/admin/coupons, /api/admin/coupons/{id}. Status 200/400/401/403/404/409 theo spec.

- Human decision: ACCEPT
- Follow-up: Audit tay: percent exclusiveMinimum 0, duplicate 409, DELETE 404. Khớp CSV.

AUDIT-15

- Tool: Claude Code (Opus 5)
- Date/time: 2026-09-01T11:00:00+07:00
- Task: Nhóm 69 assertion fail → bug report
- Prompt:

Từ Newman Discovery (86 req, 69 fail) nhóm thành bug distinct. Spec oracle. Không bịa hostname. Gắn case ID.

- AI output: (rút gọn; full: bug-reports/member-3.md)

17 bug: register no-validate; percent formula; C3 >; C4 no-auth; C5 omit user_id; IDOR; SEC-03; DELETE always 200; duplicate 500; no create-validate; path mismatch.

- Human decision: REVISE
- Follow-up: Người chốt 17 ID (BUG-M3-001..017), severity, tách bug AI bắt được vs bug human-added bắt được.

Tóm tắt quyết định

Quyết định	Số phiên
ACCEPT	4
REVISE	11
REJECT	0

Không phiên nào REJECT — output AI luôn dùng được sau khi người sửa expected / bổ sung human-added. Đây đúng tinh thần đề: AI là assistant, người chịu trách nhiệm oracle.

Công cụ không dùng

Không dùng ChatGPT, Gemini, Copilot, Cursor, Promptfoo, DeepEval, Ragas. Toàn bộ prompting + skill chạy trên Claude Code.

